

“More than a technical problem, open source management is a business problem”

In a candid conversation with OSFY's Yashasvini Razdan, Martin Callinan, director, and Prashant Singh Baghel, senior consultant at Source Code Control emphasised aligning open source practices with overall business strategies. They flagged it as a critical business concern, urging proactive handling of compliance issues tied to open source components in software.



MARTIN CALLINAN
director, Source Code Control



PRASHANT SINGH BAGHEL
senior consultant,
Source Code Control

Q: What is the significance of open source for Source Code Control?

M & P: More than a technical problem, open source management is a business problem, revolving around the potential exploitation of software leading to legal action, customer compensation, and compliance issues. Industry statistics indicate that up to 90% of modern software is composed of open source components. This demonstrates the value of open source to aid and speed up software development but, from our experience, very few companies realise that, leading them to overlook the need for open source management. Also, there is a prevailing misconception that open source is free. There is a cost associated with it that most people don't understand, which can later lead to monetary or reputational damage. The term 'open source' carries different meanings depending on the licence. Over 2,000 variants of open source licences with distinct obligations have been documented. Understanding these licences is crucial for mitigating various risks for commercial companies, which is where we specialise.

Q. How are you advising your clients or prospective potential customers regarding open source compliance?

M & P: We categorise it into three fundamental risks: operational risk, licensing risk, and vulnerability risk. Vulnerability risks are paramount, drawing significant attention, while licensing and operational aspects are often sidelined. Our approach involves consolidating all these aspects, emphasising the need to consider them collectively. Along with vulnerabilities, equal awareness should extend to licensing issues. Looking into your code today is crucial, as issues may arise even after five years, with potential

changes in development teams. We try to encompass and comprehensively address all open source-related risks and present them to our customers. We also assist companies in adopting the ISO 5230 standard, emphasising trust-building in the software supply chain. This standard becomes a competitive advantage when bidding for business, demonstrating a commitment to delivering secure and quality software.

Q. How do open source regulations affect Indian companies exporting software, and are there associated commercial risks for them?

M: In the light of the White House Executive Order and EU Cyber Resilience Act, software companies may face challenges in selling their solutions to a significant portion of the market. While the impact is just beginning, evidence suggests that sales teams, aiming to expand business in regions like Europe and the US, are encountering requirements for a Software Bill of Materials as part of the application or request for proposal process. This requirement compels sales teams to communicate this need back to their development teams, initiating the process of adapting to these new compliance standards.

Q. What is a 'Software Bill of Materials' and why is it important?

M: In essence, we enable companies to maintain transparency regarding the composition of their software through reports, akin to a food packaging label listing ingredients. This report is the Software Bill of Materials (SBOM) that provides customers with a comprehensive view of the software's components, enabling continuous monitoring and compliance alerting, which ensures that potential vulnerabilities are addressed well

before software is shipped. The aim is to establish a professionally managed open source tool, where code undergoes thorough compliance and security testing. This methodology, referred to as "secure by design," emphasises proactive security measures from the project's inception.

Q. What is the need for setting up an Open Source Program Office (OSPO)?

M: OSPOs act as a bridge, providing tools, knowledge, and guidance to address these diverse concerns. They interpret legal requirements, create tools, documentation, and educational resources, and manage processes. This allows developers to concentrate on their creative work without dealing with compliance issues directly. OSPOs facilitate communication between legal and commercial teams, ensuring that all aspects align to meet customer demands and business objectives.

Q. What is Source Code Control all about?

M: Source Code Control, as the name suggests, helps companies that develop or produce software, to manage and control software supply chain risks and be able to demonstrate the quality of the software they produce. The risks we target are two-fold — those associated with intellectual property, and risks associated with security vulnerabilities in components and libraries. We specialise in helping companies implement tools and processes to both mitigate these risks and be able to demonstrate to customers, prospects, and partners they are not passing these risks on to them. We also help organisations acquiring software solutions to implement strategies to benchmark suppliers and their ability to manage IP and security risks in the software they are supplying.